

Web VAPT Section 02 - Passive and Active Reconnaissance

Professional documentation for target surface review, HTTP checks, Nmap, and WhatWeb-based discovery.

Enterprise Security Assessment Lab

PROJECT AREA	Web Application Vulnerability Assessment and Penetration Testing
PRIMARY TARGET	DVWA running in local lab environment
TESTING ENVIRONMENT	Kali Linux attack machine with Docker-based vulnerable target
PREPARED BY	Jagriti Banerjee
DOCUMENT TYPE	Individual Web VAPT Attack-Section PDF

AUTHORIZED LAB TESTING ONLY

1. Document Purpose

This individual PDF documents the Web VAPT attack section titled 'Passive and Active Reconnaissance'. It is designed for the Enterprise Security Assessment Lab GitHub portfolio and describes the objective, tooling, commands, sanitized output, evidence mapping, security interpretation, remediation, and redaction requirements for this specific section.

This document is written as a public portfolio version. It does not contain live client data, production system details, unredacted credentials, session cookies, raw hash dumps, or destructive attack instructions.

Field	Details
Project Area	Web Application Vulnerability Assessment and Penetration Testing
Primary Target	DVWA running in a local lab environment
Testing Environment	Kali Linux attack machine with Docker-based vulnerable target
Testing Style	Reconnaissance -> Enumeration -> Manual validation -> Exploitation proof -> Evidence capture
Methodology Reference	OWASP Web Security Testing methodology, OWASP Top 10, and PTES-style workflow
Prepared By	Jagriti Banerjee

2. Section Overview

Item	Details
Section Number	02
Section Title	Web VAPT Section 02 - Passive and Active Reconnaissance
Risk / Severity Style	Reconnaissance / Informational
OWASP Mapping	Supports A05 Security Misconfiguration and A06 Vulnerable and Outdated Components review.
Primary Evidence Count	8

2.1 Objectives

- Understand the visible target surface before exploitation.
- Identify exposed ports and services.
- Collect HTTP response and header information.
- Fingerprint the web stack.
- Build a basis for later vulnerability validation.

2.2 Tools Used

Tool	Purpose / Use in this section
curl	HTTP header and endpoint testing.
Nmap	Port and service discovery.
WhatWeb	Technology fingerprinting.
Browser	Manual verification and proof screenshots.
DVWA	Intentionally vulnerable application used for validation.

3. Methodology and Execution Workflow

The execution workflow follows a controlled lab approach: confirm authorization and target scope, run only the tools required for the section, save outputs, validate observations manually where applicable, capture screenshots, redact sensitive values, and document findings without exaggeration.

3.1 Command Reference

```
# Passive / basic HTTP checks
curl -I http://127.0.0.1:8081

# Technology fingerprinting
whatweb http://127.0.0.1:8081

# Nmap service and script scan
nmap -sV -sC -A -p- 127.0.0.1 -oN tool-outputs/nmap-full-port-scan-output.txt
```

3.2 Expected / Sanitized Output

HTTP service responded successfully.
Nmap confirmed reachable service exposure.
WhatWeb identified application/server technologies.
Recon screenshots captured to support the assessment workflow.

3.3 Validation Criteria

- The target must be the local DVWA or authorized lab environment only.
- The output must match the intended section objective.
- Evidence screenshots must clearly show the validation result or tool output.
- Any sensitive values must be blurred, cropped, removed, or replaced with placeholders.
- The section must not claim findings that are not supported by evidence.

4. Evidence Mapping

Evidence File	Evidence Type / Reason
Passive-Recon-p1.png	Passive reconnaissance evidence.
Passive-Recon-p2.png	Passive reconnaissance evidence.
Passive-Recon-p3.png	Passive reconnaissance evidence.
05-nmap-full-port-scan-output.png	Nmap service discovery evidence.
08-whatweb-tech-fingerprint-p1.png	WhatWeb technology fingerprinting evidence.
08-whatweb-tech-fingerprint-p2.png	WhatWeb technology fingerprinting evidence.
08-whatweb-tech-fingerprint-p3.png	WhatWeb technology fingerprinting evidence.
08-whatweb-tech-fingerprint-p4.png	WhatWeb technology fingerprinting evidence.

5. Professional Security Analysis

Reconnaissance identifies what exists before deeper testing begins. This reduces guesswork and makes later vulnerability testing more targeted.

The combination of curl, Nmap, and WhatWeb gives both network-level and application-level context.

Because this is a lab target, the purpose is not stealth; the purpose is controlled documentation and repeatable evidence.

5.1 Why This Section Matters

This section matters because professional VAPT is not only about running a tool. It requires a clear objective, controlled execution, evidence capture, correct interpretation, and practical remediation. For recruiters and reviewers, this PDF shows that the work was structured, documented, and aligned with real security methodology.

5.2 Common Mistakes to Avoid

- Uploading raw outputs that expose cookies, hashes, paths, or credentials.
- Claiming production-level impact without production context.
- Reporting scanner output as a confirmed vulnerability without validation.
- Using unclear screenshots that do not show the relevant result.
- Mixing unrelated phases in one evidence file without explanation.

6. Risk Analysis

- Technology disclosure may help attackers select targeted payloads.
- Unnecessary exposed services can expand attack surface.
- Verbose headers can reveal stack details and version information.

6.1 Real-World Impact Statement

The real-world impact depends on the affected asset, authentication context, data sensitivity, privilege level, exposed functionality, and compensating controls. Because this project uses DVWA in a lab, severity is described as a real-world context estimate rather than a formal client CVSS score.

7. Remediation and Hardening Guidance

- Reduce unnecessary server banners and technology headers.
- Close unused ports and services.
- Restrict administrative interfaces.
- Regularly perform asset discovery and compare results to expected exposure.

7.1 Verification After Remediation

- 1 Re-run the original test case in the lab or development environment.
- 2 Confirm that the previous vulnerable behaviour no longer appears.
- 3 Check server logs for blocked or rejected attempts.
- 4 Capture new evidence showing the fix or defensive control.
- 5 Update the report status from validated/open to fixed/retested if applicable.

8. GitHub Redaction and Publishing Checklist

Cookies, hashes, credentials, session IDs, shell paths, database output, and private details must be redacted before public upload.

Item	Action Before Upload
PHPSESSID / Cookies	Blur or replace with <REDACTED_COOKIE>.
Password hashes	Blur or replace with <REDACTED_HASH>.
Cracked passwords	Do not publish; replace with <REDACTED_PASSWORD>.
Database dumps	Crop, blur, or summarize instead of uploading raw data.
Webshell paths/files	Do not upload shell source files; redact paths if needed.
Local usernames/paths	Blur if private or unnecessary.
Tool raw outputs	Upload only sanitized outputs or summary documents.

8.1 Safe Git Commands Before Push

```
git status
git diff --cached
git diff --cached | grep -iE "password|secret|token|cookie|PHPSESSID|hash|credential"
```

9. Conclusion

This document completes the individual Web VAPT PDF for Section 02. It documents the section objective, execution workflow, evidence mapping, professional interpretation, risk, remediation, and GitHub safety checks. The content is aligned to the actual Enterprise Security Assessment Lab Web VAPT evidence set and avoids unsupported production claims.

Legal and ethical notice: This documentation is for authorized lab testing only. Do not apply these techniques to public or third-party systems without explicit written permission.